

Firewalling the Net

S D Hubbard and J C Sager

To connect any stand-alone enterprise network to the Internet in a safe and secure manner, it is necessary to erect a 'firewall' at the interface between the internal and external networks. We review the current state of firewall technology and describe the principles behind the solutions that are being adopted by BT. We also describe how companies are presently utilising the bandwidth of the Internet to extend their internal intranets using cryptographic techniques and indicate some of the directions in which firewall research will be going in the next few years.

1. Introduction

Today, most businesses of any size have one or more internal data networks interconnecting their computing resources. More are now looking to connect their internal networks to the world-wide Internet.

An Internet connection offers a business a number of valuable facilities, for example:

- easy, reliable communications with employees and customers,
- the ability to publish and to share information,
- the ability to sell products and services to the global electronic community on a 24-hour basis,
- access to a large repository of useful information.

There are also many potential security problems associated with connecting a business to the Internet. If it were to connect to the Internet in a completely open manner, with no security mechanisms separating the internal network from the Internet, it would become vulnerable to many potential threats. Some of these are:

- hackers attempting to gain unauthorised access to internal computing resources, and also trying to prevent legitimate users from using those resources — having gained access, they might attempt to use the resources for their own nefarious purposes,
- competitors attempting to impede the business electronically,
- business information being read, changed or destroyed by an unauthorised person, any of which could have a devastating effect on the viability of the business,

- a bad security breach on a machine holding customers' information leading to the possibility of expensive legal action against the business.

To minimise the risks of connecting a network to the Internet, it is necessary to protect the internal network from the Internet and to limit the scope of access from one network to the other. A 'firewall' is used for this purpose. Essentially, a firewall is a piece of dedicated hardware, or software running on a router or dedicated host, which is situated at the interface between the internal trusted network and the wider world represented by the Internet, as illustrated in Fig 1. The term probably comes from the aviation industry, where a firewall is the bulkhead which sits between the engine and passengers in a light aircraft, protecting them from any engine fire that may develop.

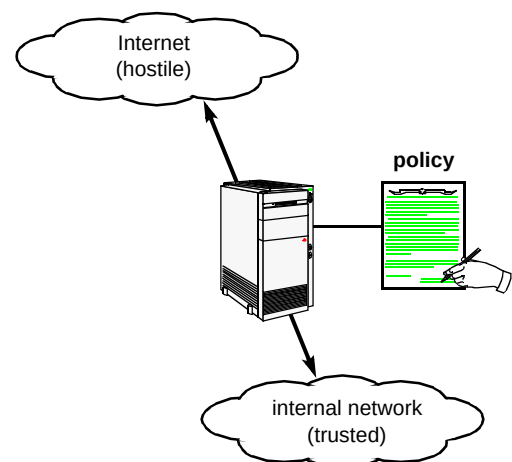


Fig 1 Where a firewall sits and what it does.

The aim of the firewall is to implement a security policy that has been set by the business with respect to connections to the Internet. The firewall sits on the IP network and examines all the IP packets that reach it. If the internal Local Area Network (LAN) is configured with only one physical connection between it and the Internet, the firewall is able to examine all packets that are travelling between the internal LAN and the Internet. As each packet arrives, the firewall checks it against a set of rules which implement the security policy, and passes the packet only if the rules say that it is allowed to pass. By default, all other packets are thrown away, although in some cases the firewall might return the rejected packets to the sender, or send a control message to say that the connection has been dropped. Firewalls are capable of applying a security policy to packets going in either direction.

2. Security policy

The organisation's security policy is a document that is used to define the rules that are applied by the firewall. Chapman and Zwicky [1] have written down a simple set of rules for defining such a policy. The safest security policy for an organisation is represented by: '*Deny everything which is not expressly permitted*'. This policy should be used wherever possible, because, by keeping the firewall configuration tight, any possible security problems are more easily identified.

3. Firewall management

The problem of managing a firewall can be split into three main tasks. Each task must be backed up by appropriate business processes that should form part of the organisation's quality management system.

The first task is to gather the requirements for the firewall and to generate the firewall security policy from those requirements. Firewall requirements need to be reviewed regularly, as users' needs change. Such a review process enables the organisation to be confident that nothing has been missed.

The second main task of firewall management is to define a set of processes that cover how to spot and to act upon potential attacks. A key part of any security system is to be able to ascertain, at any time, what is going on, so that any potential security breaches can be detected. This is particularly important with Internet security. It is vital that systematic logs are kept, and that they are analysed on a regular basis. In the event of a security breach, it is also necessary to define a process which covers how the firewall and the internal networks are returned to a secure state.

Finally, the third main task is to manage the continuous improvement of the firewall. The processes that are defined under this task should cover areas such as how the firewall

should be changed and tested in the light of attacks that are detected, and should also cover regular penetration testing by an independent security team.

4. Firewall building blocks

Three main techniques are used, alone or in combination, to build firewalls. These are:

- packet filtering or screening,
- application proxies,
- address or port translation

4.1 Packet filtering

The packet filter firewall operates at the level of the IP packet. The following sub-sections consider the various features of the packet normally used for filtering. In this and all following discussion, a packet that is described as travelling in the outward or outbound direction means that it is going from a trusted, internal network to an untrusted external network that is usually the Internet.

Source IP address (IP header)

IP addresses are 32 bits (4 bytes) long, and uniquely identify a host on the Internet.

The source address is the IP address of the host where the packet originated. Typically, for inbound services to public servers, the allowed source address range might be anywhere in the possible range of IP addresses. For outbound services, the allowed source may be any IP address that is used by the internal network. Applying a filter to the source IP address in the outward direction gives the ability to control which machines on the internal network have access to the Internet. Filtering on the source IP address in the inward direction controls which external hosts are able to connect to the internal network. Where a trusted connection to the internal network from an external source is being set up, it is a very good idea to define the allowed source addresses exactly, so that only known machines can connect to the internal network. Filtering out packets in the incoming direction using the internal address range as a source address gives protection from hosts on the outside which may be pretending to be internal machines, *i.e.* external hosts which are trying to 'spoof' internal IP addresses.

Destination IP address (IP header)

This is the IP address of the destination host. For a typical business, filtering on the destination IP address is useful in the incoming direction, where it can be used to allow specific services through to certain machines, such as

a mail or World Wide Web (WWW) server. If used in the outgoing direction, destination address filtering implements a 'white list' of allowed sites on the Internet to which internal users are allowed to connect. This function might be considered to be useful in some circumstances, where the firewalled network is that of a bank or a school, perhaps, but in these cases it is easier to use proxy servers to implement the white list. In any case, a white list adds a considerable management overhead to the maintenance of the firewall.

IP protocol type (IP header)

This defines whether the packet is a TCP (transmission control protocol), UDP (user datagram protocol), ICMP (Internet control message protocol) or some other type of packet. It is possible to create completely different rule sets for each type of packet.

IP options field (IP header)

In the current version of IP, IP options are rarely used. However, one particular option — source routing, which allows the source to specify part or all of the route to be used when sending the packet — is a particular security hazard. Almost all firewalls are configured to drop any packets with source routing enabled.

Source and destination port number (TCP/UDP header)

The standard stream (TCP) and datagram (UDP) transport services which run on top of IP use the concept of a port number to distinguish different connections at a particular host. By convention, many standard services are offered at 'well-known' ports. For example the Internet mail service, SMTP, uses TCP port 25, and the network time

protocol (NTP) uses UDP port 123. The port number is a two-byte number, giving a possible range from 1 to 65535 (0 is not used). All TCP and UDP packets therefore carry four identifiers — source and destination address and source and destination port — which uniquely identify a particular connection or association between two hosts. By convention, port numbers below 1024 are considered special, in that many well-known services reside there, and hosts choosing a port number to initiate a connection invariably choose from the range above 1023. Indeed, this is enforced on UNIX systems by the privilege and protection mechanisms built into the operating system, where it is only possible for processes running with superuser or root privilege to initiate a connection on a port below 1024.

This is illustrated for a typical WWW server in Fig 2 where SP refers to the source port number and DP refers to the destination port.

By using a combination of source and destination IP addresses and port numbers, a packet filter can limit external access to specific internal services as well as specific internal hosts. For example, a rule to support incoming e-mail should allow incoming TCP connections only on port 25 (for SMTP) and only to the specific host used as the company's incoming mail server.

TCP flags (TCP header)

The TCP header contains a flags field which is used to control the operation of a TCP connection. Two of these flags, the SYN and ACK flags, are very useful for packet filtering. Figure 2 shows the establishment phase of a TCP connection between a client and a Web server (which is listening on port 80). The initial packet has the SYN flag set, indicating a connection request. The response from the

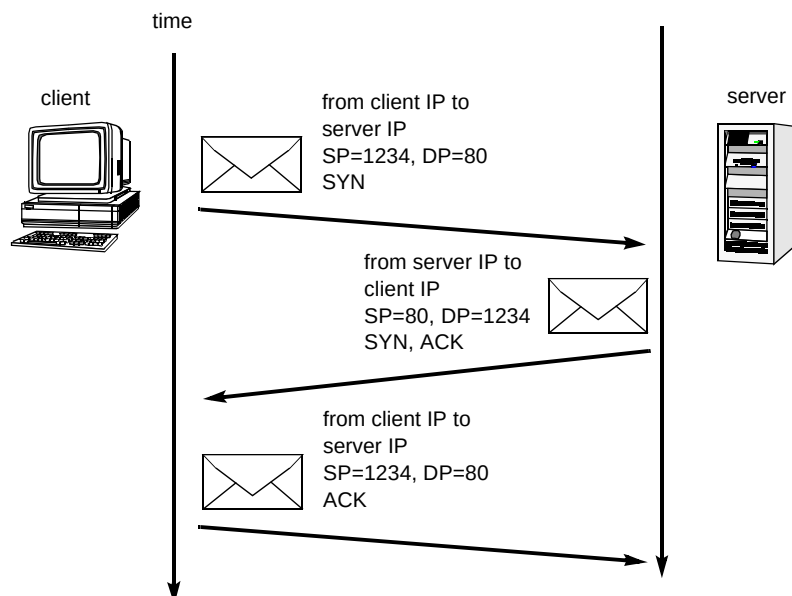


Fig 2 The start of a WWW connection from the client to a server.

server has both the SYN and ACK flags set, and the establishment of the connection is confirmed by a packet from the client with just the ACK flag set. It is possible to configure a packet filter to drop all incoming packets with just the SYN flag set, but to allow incoming packets to ports above 1023 with the ACK flag set or both SYN and ACK flags set. This would prevent incoming connection attempts on all ports but would allow connections that have been established from the inside (SYN only on outgoing packets, SYN ACK and ACK on incoming packets).

Filtering UDP connections

UDP is a connectionless protocol; the sender of UDP packets does not know whether they are received as there is no acknowledgement mechanism. This means that the UDP transport mechanism is inherently unreliable. There is no explicit connection establishment process, so it is not possible to determine which UDP packets are those at the start of a UDP connection. The connection is inherently 'stateless' — the UDP layer on both sides of the association keeps no information about its state between packets. However, some firewall products are capable of remembering the state of a UDP connection. When they detect an outbound UDP packet for example, they remember its source and destination port numbers, and are able to allow the matching inbound UDP response to pass. Typically, the firewall will remember the state of a UDP connection for a time period ranging from a few seconds to a few minutes, after which it will be forgotten. By remembering the state of connections, the firewall is effectively changing its packet filtering rules on the fly. This capability is known as 'dynamic packet filtering'.

Filtering ICMP

ICMP packets are used for sending control messages between hosts. Unlike TCP and UDP packets, they do not have source and destination port numbers. Filtering of ICMP messages is usually carried out by message type. It is normally considered to be safe to allow ICMP echo request and echo response messages across the firewall — these messages are used by 'ping'. However, many of the other ICMP messages are not so safe. In particular, ICMP redirect messages should be blocked at the firewall, since responses to them are very useful for mapping a network.

Packet filtering for TCP and UDP services

Packet filtering firewalls are easily configured for specific TCP and UDP services. It is merely necessary to know, for all hosts on the internal network:

- what the services are to which one is trying to allow or deny access — for any service, the service is defined by which port(s) it uses, and what type of packets (TCP

or UDP) it sends, e.g. the network remote control service known as Timbuktu [2] uses UDP port 407 and TCP ports 1417-1420 inclusive,

- the allowed source and destination IP address ranges for incoming and outgoing packets using the service.

Once the above information has been gathered, it is relatively straightforward to turn it into a set of access lists that can be applied, for example, to the interfaces of a router.

Filtering RPC applications

Sun remote procedure call (RPC)-based services (network file system (NFS) and network information services or Yellow Pages are two of the most well known) use a daemon known as the portmapper to tell possible clients on which port(s) they are listening. When an RPC server starts, it allocates one or more randomly numbered TCP and /or UDP ports to itself. The server then tells the portmapper its unique RPC service number and the port numbers that it has chosen. The portmapper maintains this map. When a potential RPC client wishes to contact the server, it first contacts the server's portmapper to find out which ports to use for the service it requires. This is shown in Fig 3.

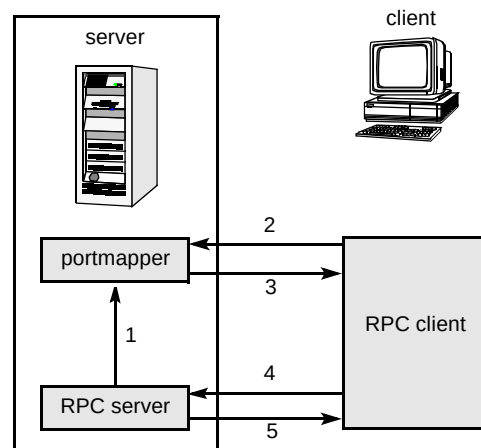


Fig 3 Using the portmapper to find out about RPC services on a system. 1. When it starts, the RPC server registers its RPC program number and a port number with the portmapper. 2. A potential client contacts the portmapper to find out what port the service it needs is listening on. 3. The portmapper tells the RPC client what port number it requires for the requested RPC program number. 4 & 5. The RPC client contacts the RPC server on the port number given out by the portmapper. The interaction continues without further intervention from the portmapper.

This indirect mapping of the port number to the RPC service makes life difficult for a standard packet-screening firewall. Unless a firewall can contact the portmapper direct to find out which ports are currently in use, it cannot be sure of blocking an RPC service by blocking the particular port numbers that it uses. In the event, many RPC services are

not very random in the port numbers that they choose — most implementations of NFS, for example, use port 2049 — and it is therefore usually possible to block access to NFS by blocking this port. However, this cannot be guaranteed.

Advantages of standard packet filters

The main advantages of using a standard packet-screen firewall are fourfold.

- They are effectively free, since the ability to screen packets on source and destination IP address, packet type, port number and so on comes as part of the standard router configuration software. It is not absolutely necessary to purchase any hardware to be able to do packet filtering.
- They are extremely flexible, are easily configured to allow or to block specific services if the port number(s) and packet types are known. Packet screens are particularly useful for people who work with new Internet protocols, since it is easy to configure them to cope with new TCP and UDP protocols.
- They are fast.
- The installation of a packet filtering firewall does not require any action on the part of the network users.

Disadvantages of standard packet filters

The main disadvantages of standard packet-screen firewalls are summarised below.

- In standard form, such as a router packet screen, they are not able to filter stateless UDP packets effectively.
- To allow normal mode outbound FTP (file transfer protocol) to work with a standard packet screen, it is necessary to allow inbound connections on all ports above 1023 (an inward connection is made from port 20 on the server to a port numbered over 1023 on the client to set up the FTP data channel in an outbound FTP session). Outbound FTP is seen as a desirable service by most users, which leaves a large potential security hole in a standard packet screen — this hole can be closed somewhat by requiring that passive-mode FTP clients are used, since passive-mode FTP does not use an inbound connection, but instead informs the server of which port it has chosen for the data connection. Unfortunately though, there are few Unix clients that support passive-mode FTP.
- The indirectly mapped RPC services are also not easily filtered by a standard packet screen, because the port number for a specific service is chosen by the portmapper. Although it is possible to block access to the portmapper using a standard packet screen, as this

service is always guaranteed to run on port 111, this does not prevent a potential attacker from running a strobe attack on the host itself to discover which ports have services listening for connections on them.

- Because packet-screening firewalls work at the level of the network and transport protocols, they cannot tell the difference, for example, between an HTTP (World Wide Web) packet on port 80 and a packet that forms part of a Telnet session on the same port. If a firewall is configured to allow through inbound packets with a destination port of port 80, it will allow through both of these hypothetical packets. If the intention was to allow only the HTTP packets to pass, this could be considered to be a security problem.

4.2 Application proxies

Application proxies work at the level of the application protocol, rather than at the level of the network and transport protocols. A WWW proxy, for example, is able to decode the contents of a WWW packet so that it can be forwarded by the proxy to its ultimate destination. Application proxies are processes that are run on a machine known as a bastion host, that is sited on a network known as a demilitarised zone (DMZ). A typical configuration is shown in Fig 4. Mail (SMTP) and news (NNTP) are services that are proxied naturally, and are usually handled for a single LAN by one server on behalf of the other users.

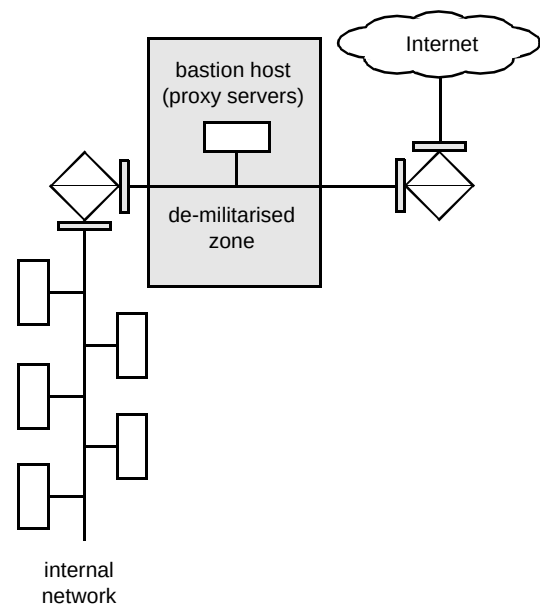


Fig 4 Typical proxy server firewall configuration, showing demilitarised zone.

The use of application proxies gives the organisation tight control over which services the people on the internal network are able to access. The act of installing a WWW proxy, for example, is the only thing that will allow internal users to access WWW servers on the external network.

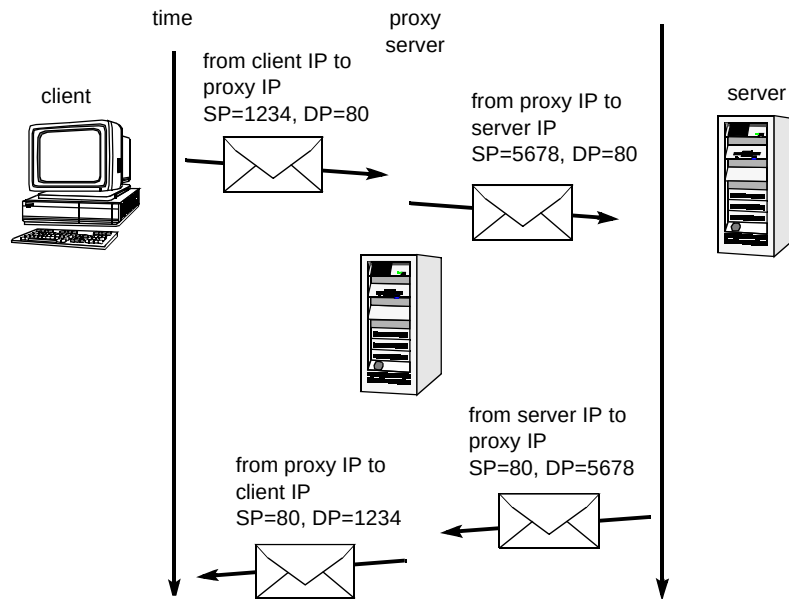


Fig 5 A WWW request via a proxy server.

A proxy server separates out internal packets from external packets (see Fig 5). The proxy does this in the following way:

- the client machine contacts the proxy and sends the request for the desired URL to it using the http protocol,
- if the proxy does not already have the requested page in its cache, the proxy rewrites the request with its own IP address as the source and forwards it to the external server using HTTP,
- the proxy receives the information requested, rewrites the information in packets with its own source address and forwards the new packets to the client that requested the URL; often, a WWW proxy will also store the information that it fetches in a cache for use the next time someone requests the same URL, which has the useful effect of boosting performance for frequently requested WWW pages.

Advantages of application proxies

The use of a proxy gives the firewall designer tight control over the services that are available. Many proxies (typically FTP and Telnet, but also HTTP) support some form of user authentication, so that it is possible to account for people's use of Internet services, and if desired, to restrict the availability of the service to specific users.

Their ability to support strong user authentication, using a mechanism such as a one-time password token, is very useful in setting up carefully controlled connections into the network from the outside.

A firewall that only uses application proxies is very secure. The only types of packets that can flow through it are those that are supported by the currently active proxies. There is no danger of a new Internet protocol coming along and causing security problems, because if there is no proxy, there is no way that the packet will get through the bastion host.

The proxy can be used to hide the details of the internal network from the outside world, since all requests appear to come from the proxy's IP address. This means that it is possible to use unregistered or RFC 1918 addresses on the internal network [3].

Disadvantages of application proxies

Only a limited number of proxies exist. Typically, proxies can be found for FTP, Telnet, HTTP, X Windows, rlogin, SMTP and NNTP. While this is sufficient for users in most businesses, this limited selection of services is unlikely to satisfy the requirements of some groups of users, such as people in Research and Development in Internet-related businesses.

The use of a proxy requires some configuration of client applications. This can lead to an increase in the technical support costs for the network as users require help with configuration.

With the exception of RealAudio, there are no proxy servers available for any of the new audio- and video-streaming-based services, and there are certainly none available for IP multicast services, such as those available on the multicast Internet backbone [4]. In fact, it is technically very difficult to write a proxy for multicast

services because of the way that these services operate. While this may seem to be a minor inconvenience at the moment, the development of IP services is progressing at such a rate that the Internet may rapidly become a viable medium for distributing intra-business video communications. If this were to happen, the inability to handle multicast services using application proxies could become a major problem.

Application proxies work at the highest level of the OSI protocol stack. Because they carry out a great deal of processing for each packet, even powerful servers can only support a limited number of simultaneous connections.

4.3 Circuit-level gateways

A circuit-level gateway is an extreme form of proxy server. It is similar to a packet screen, in that it works at the transport protocol rather than the application protocol level. Circuit-level gateways, which are also known as generic proxy servers, work by setting up 'virtual circuits' between the internal and external hosts without interpreting the application protocol. A standard proxy requires its users to modify their procedures (i.e. to connect to the proxy rather than their required destination) in order to use it. Circuit-level proxies do not have any knowledge of the application; to use one requires that the proxy has been told where it is to connect to by some other means, possibly by using a modified form of the client.

The main advantage of circuit-level proxies is that they can support a wide range of protocols.

However, some protocols, such as FTP, cannot be supported by circuit-level proxies, since they communicate port data from the client to the server. Also, they control connections only on the basis of their source and destination and cannot tell whether such a connection is safe, in a similar manner to packet screens.

4.4 Address-translating gateways

From the security point of view, one of the main advantages of using a proxy server is that it completely hides the details of the internal network from the outside, as all packets that pass through it are rewritten with the source address of the proxy. This hiding of internal IP addresses can also be accomplished without the use of a proxy server by using an address-translating gateway.

A firewall configuration using an address-translating gateway is illustrated schematically in Fig 6.

The gateway is placed at the interface of the internal

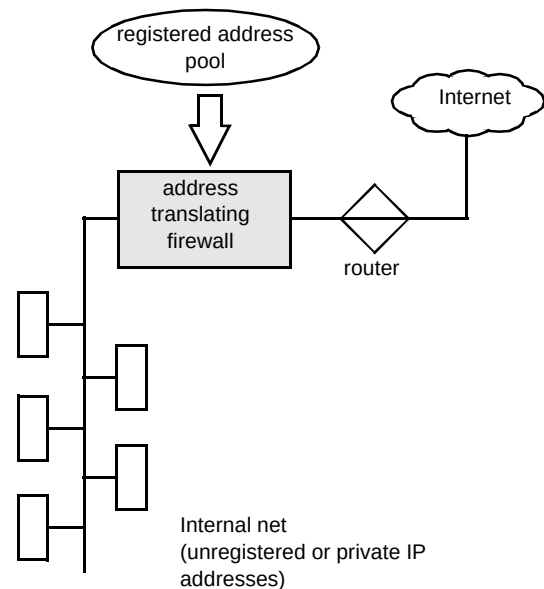


Fig 6 An address-translating firewall.

the outside network from a machine on the inside arrives at the internal interface, the gateway assigns the internal host an IP address taken from its global allocation pool. The gateway remembers the mapping, and sends the packet onwards to its destination with the new source IP address. When the response is received, the gateway checks its mapping and rewrites the packet with its correct internal destination IP address before sending it out on to the internal network.

The use of an address-translating gateway has several advantages as listed below.

It completely hides the details of the internal network. None of the IP addresses that are visible to the outside world are the real internal addresses of the machines on the internal network.

Although it is still necessary to set up static mappings for servers on the inside that need to talk to the outside world on a permanent basis (such as mail servers or public WWW servers), their real IP addresses are not disclosed to the outside world.

Although it completely frees the network designer to use any IP addresses for the internal network, whether registered or not, if registered addresses are used, the internal network is denied access to the real owners of the registered addresses, so this is not recommended. The best solution is to design a network using RFC 1918 addresses that are never advertised to the outside world. A firewall that uses just such a solution will be described in a following section.

The firewall can be extremely fast. One commercial address-translating product has an operating system of about 60K bytes in size, of which 10K bytes comprise the

kernel. It can easily cope with links of up to 45 Mbit/s and more than 16 000 simultaneous connections.

The firewall's address map is dynamic, meaning that it is impossible for an outsider to tell if two connections with the same source IP address actually came from the same internal host.

5. Combining firewall techniques

The most secure firewall architectures do not rely entirely on one type of firewall or another for their security. While space does not permit a comprehensive review, some example firewall architectures that use two or more firewall technologies should be mentioned. A more complete critique of firewall architectures can be found in Chapman and Zwicky [1].

The first example is a suitable firewall configuration for a medium-to-large business that wishes to regulate tightly how its employees use the Internet. Figure 7 illustrates how a proxy-based firewall can be made more secure by using routers and packet screens to prevent any direct communication between the internal network and the Internet.

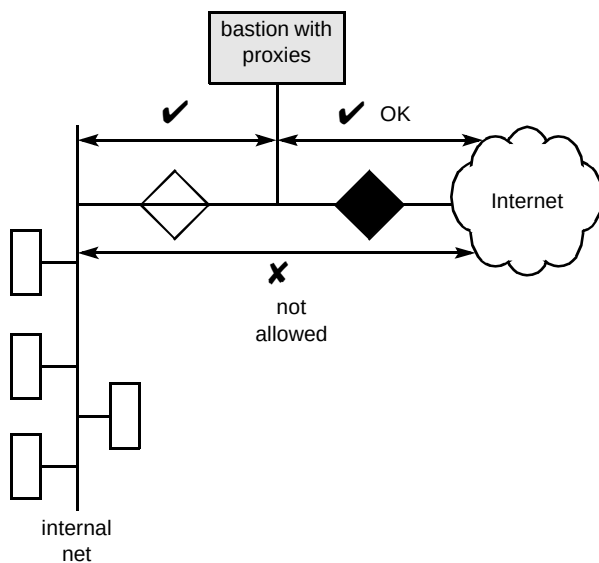


Fig 7 Using packet screens on routers to force communications to go through the bastion host.

In this example, the bastion host with the proxy servers is on the DMZ as described above. However, the routers at either end of the DMZ are configured in the following way.

The router to the Internet has a packet screen that is configured to allow only packets with the destination address of the bastion host to pass. In addition, its routing parameters are set so that its internal interface (the one on the DMZ) cannot route packets to anywhere other than the bastion host.

In a similar manner, the router that separates the internal network from the DMZ has a screen that prevents any packets passing through it which are not destined for the bastion host (in the outbound direction) or come from it (in the inbound direction). Its routing tables are also set up so that it cannot send packets direct to the outer router.

This configuration is highly secure, since it forces all packets to and from the Internet to go through the bastion host and its proxy servers. Also, only the services that are offered on the bastion host can be used by internal users to connect to the Internet. The firewall also has all the disadvantages of application proxies as described above.

A variation on the standard proxy-server architecture consists of expanding the DMZ to cover a significant number of users' machines [5]. In this architecture, illustrated in Fig 8, two packet screens are used to protect the DMZ network from the Internet and the internal network.

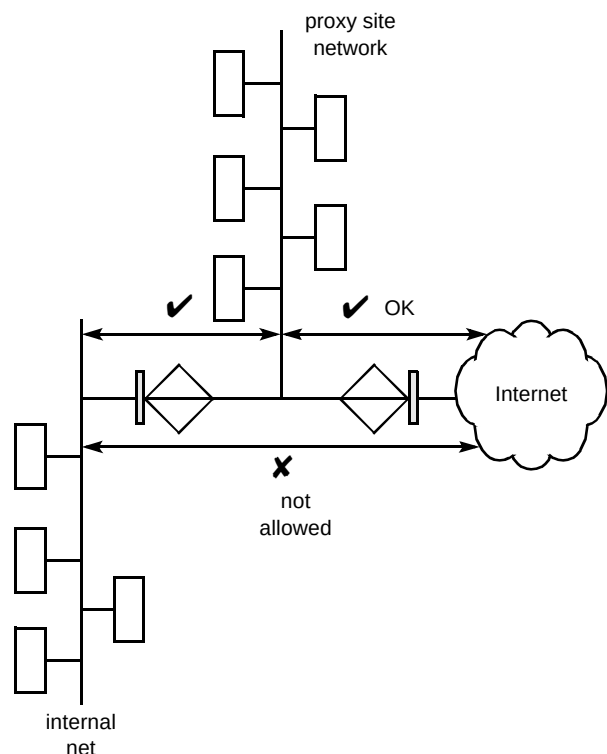


Fig 8 Accommodating conflicting access requirements using a DMZ network.

The two routers at either side of the DMZ are set up so that they cannot route direct to each other as before. This architecture can cope with apparently conflicting sets of Internet access requirements — the users on the DMZ use a packet-screen-based firewall for their communications with the Internet and can talk to anyone on the internal net, while the users on the internal net can only talk directly to anyone on the DMZ. This implies that internal users must use a proxy server on the DMZ in order to communicate with

hosts on the Internet. The architecture thus allows the users on the DMZ to have the flexibility of a packet-screen-based firewall, and at the same time allows the users on the internal network to have the security of an application proxy-based firewall. The major disadvantage of the architecture is that it places a large degree of trust in the users in the DMZ. Any DMZ host can act as a proxy server for the internal network. The administrators of the firewall must take care to ensure that the only proxy servers that are available on the DMZ to internal users are authorised and that they are properly configured. Network monitoring tools can be used to detect unauthorised proxy servers.

Packet screens are also useful in combination with address translating firewalls. Although it is possible to set up a secure connection to a single internal host for use as a WWW or mail server, any such conduit through the firewall opens up an internal host to the possibility that it might be compromised. This situation is illustrated in Fig 9.

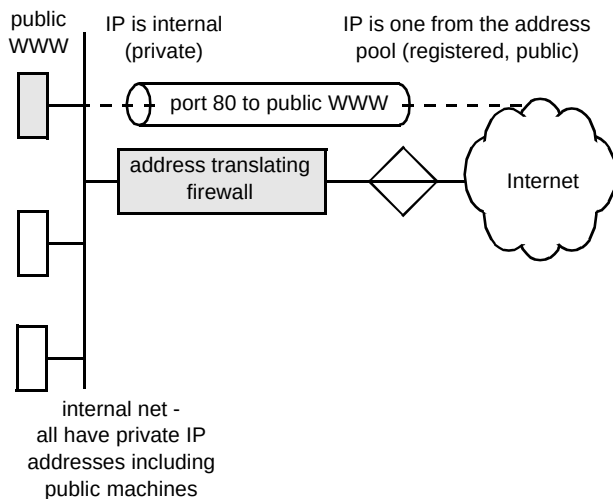


Fig 9 Setting up a secure conduit through an address-translating firewall.

With an address-translating firewall, the IP address of the public server as it is seen by the outside world is that which was assigned to it when the conduit was set up, and not its real internal IP address. However, even though conduits can be limited to connections on specific ports only, this might not satisfy the corporate security requirements. A more secure solution is to combine the address-translating firewall with a router-based packet screen to form a DMZ, and to place all the public facing servers on the DMZ, as shown in Fig 10.

In this scenario, even if one or more of the public servers are compromised, the attacker can gain no information about the internal network, since the only IP address information the server logs contain are mapped by the firewall. As far as the firewall is concerned, the public servers are outside it, and any attacks on the internal

network launched from them should be treated the same way as any other Internet based attacks. In this particular case, nothing should be allowed to get through the firewall from the Internet that does not form part of an established connection, and therefore any attacks originated from the public servers would be prevented by the firewall.

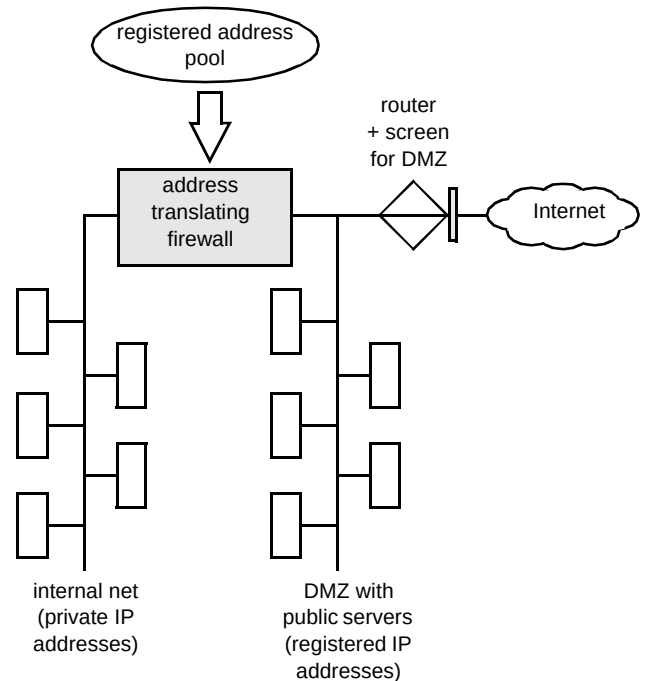


Fig 10 Address-translating firewall with an outer DMZ.

6. Added value extras

This section describes some of the facilities that have become part of commercial providers' firewall solutions in the recent past.

6.1 Stateful monitoring

Stateful monitoring was invented to solve the problem of how to screen UDP packets effectively. This function has also become known in packet filtering circles as 'dynamic packet filtering'. A firewall with a stateful monitoring function remembers the 'state' of the packets that appear at its interfaces. For example, in Fig 11, a host is sending an NTP request to a machine on the outside.

Initially, the internal host sends out a UDP packet. The contents of its IP and UDP headers are noted by the firewall as it is allowed through. Some time later, a reply is sent from the server. The firewall checks the contents of the reply packet to see if it matches any of the packets in its database. In this case, the source and destination ports and IP numbers match, so the packet is allowed through. Later, the firewall intercepts another UDP packet destined for the

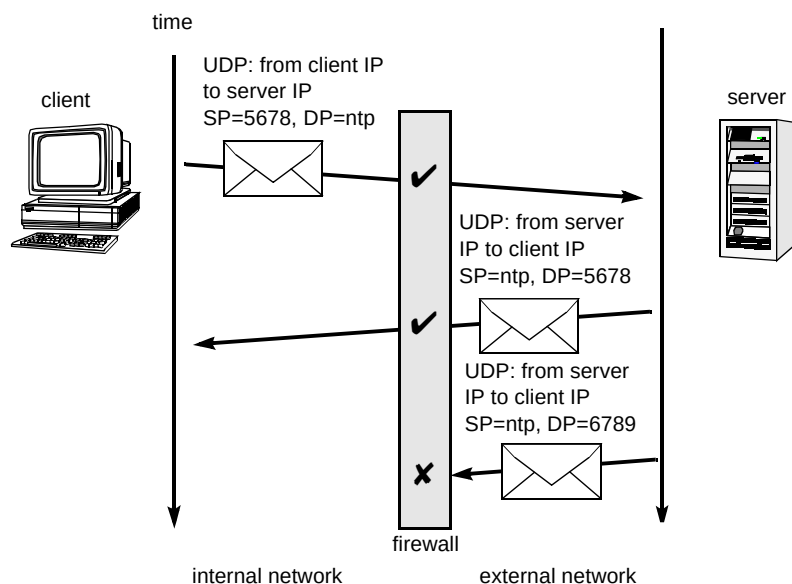


Fig 11 Stateful monitoring of a UDP packet.

same host. The details of this packet do not appear in the database and so it is rejected.

Stateful monitoring has recently been extended to TCP services too. Some of the newest firewall products are now able to tell the difference between, say, an HTTP packet on destination port 80, which may well be allowed, and a Telnet connection on the same port, which should almost certainly be denied. Such firewalls, which are still basically packet screens, have, through their stateful monitoring functionality, a degree of application level intelligence and combine the best aspects of packet screens and application proxies.

6.2 Encryption and firewalls

Consider a manager who wishes to send some sensitive corporate information to his or her colleague who works in another country. One way of using the Internet to send the information is to encrypt it using some encryption package and then to transfer it to the colleague's machine using FTP. The use of encryption has given the document a degree of confidentiality. However, it is easier for the sender if he or she does not have to remember that encryption must be used. As shown in Fig 12, a pair of firewalls can be used to set up a tunnel between the company's sites that automatically encrypts all communications between them. Thus the manager in the above scenario would be able to send the document by FTP normally, and be confident that it could not be decoded by anyone on the Internet who happened to intercept it.

The tunnel works in the following way. Firewall A is configured so that all communications to IP addresses on network B are encrypted using a key that is shared with

firewall B. Any packet arriving at firewall A destined for network B is encrypted, and a new IP header with the addresses of the firewalls is added. When the packet arrives at firewall B, it is decrypted and the original IP header retrieved. It is then forwarded to its destination.

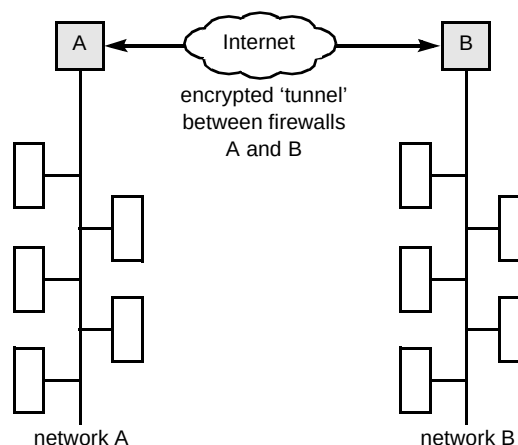


Fig 12 An IP tunnel between two networks.

All this happens in a way that is completely transparent to the users on networks A and B. As far as they are concerned, they are communicating across the Intranet between sites A and B as though they are on the same site.

6.3 IP security

The IP security (IPSec) working group of the Internet Engineering Task Force (IETF) has specified in requests for comments (RFCs) 1825-1829 [6—10] how the security mechanisms work. There are two modes of IPSec security — transport mode, which is designed for securing host-to-

host communications, and tunnel mode, which is designed for links between firewalls. Communications can be secured in one of three ways.

- An authenticating header (AH) can be added both to sign the data in the packet digitally, and, using public key encryption techniques, to provide data origin authentication [7]. AH provides a mechanism for data integrity, and using it can prevent any changes to the packet after it is sent, while not encrypting the contents of the packet.
- A transform known as the encapsulated security payload (ESP) specifies data encryption [8], which provides a means of data confidentiality, by transforming use of symmetric key encryption to protect the data.
- AH and ESP can be used in combination to provide data integrity and confidentiality.

A detailed description of the various AH and ESP transforms is beyond the scope of this paper; the reader is referred to the work of the IPSec working group in this area [11].

As in many applications of cryptography, a major area of work in the IPSec working group has concerned the problem of how the various encryption keys are distributed and managed. This problem has probably prevented the widespread adoption of IPSec technology to date. Several key management protocols have been proposed, of which two have received substantial support from the IPSEC community. Simple key interchange protocol (SKIP) has been proposed by Sun, and has been implemented by them in their Sunscreen family of products [12]. Its competitor, Internet security architecture key management protocol (ISAKMP) and its associated OAKLEY protocol [13, 14] have been adopted by Cisco and others.

7. Building a firewall — a case study

A typical, large corporate customer had a wide range of security requirements that could only be satisfied by using several types of firewall technology. In this part of the paper, we describe the process that was used in designing and implementing a firewall and secure Internet access for such a customer.

7.1 Security and network requirements

The first, and most important task was to determine the customer's Internet access and security requirements. In this example, they can be summarised as follows:

- in the outward direction, the customer wished to allow a limited standard set of services such as WWW, FTP, mail, news and Telnet,

- inward connections were not to be permitted to users' machines — they would be limited to necessary connections to well-controlled servers such as an e-mail server and a public WWW server,
- the customer wished to be able to control the access very tightly, with only a limited number of people being able to access a limited number of external sites,
- the customer wished to link its existing e-mail infrastructure to the Internet,
- they wanted to be able to introduce Internet access with as little disruption as possible to their existing IP network, which does not use registered IP addresses,
- they needed to communicate securely across the Internet with colleagues in Europe.

7.2 Implementation

The next stage was to select a firewall that would fit in to their chosen network architecture and that would fulfil their security requirements.

In this case, the screened subnet firewall architecture, as described in Chapman and Zwicky [1] was chosen. This design consists of a pair of routers with a network DMZ between them, and a bastion host network on the DMZ. This design is not quite as strict as the proxy based solution that is shown in Fig 4, as it allows certain screened traffic to flow between the routers, rather than forcing everything to go via the bastion host. This type of architecture allows public servers to be hosted on the DMZ, rather than on the inside of the firewall, which means that fewer internal hosts are open to connections from the outside world.

The combination of the need to implement the access with as little disruption to the existing IP infrastructure, and the fact that the existing IP networks had been implemented using unregistered IP addresses, implied that the firewall also required the ability to do network address translation. The hardware required to do this can be, for example, a Cisco router with the latest version of their IOS software [15], or a specialist address-translating firewall, such as the Pix, which is also sold by Cisco [16]. In this case, a separate firewall was chosen, leading to a final network configuration similar to Fig 10.

The requirement to be able to communicate securely with colleagues elsewhere on the Internet was fulfilled by the firewall's ability to implement virtual network 'tunnels' using IPSec-based encryption between sites.

The final configuration combined four types of firewall technology:

- the external router was configured with a packet screen to control access to the bastion host and public servers on the DMZ,
- the bastion host acted as a proxy for mail and news for the people on the inside — application proxies for other standard Internet services such as WWW, FTP and Telnet were also available if required,
- the address-translating firewall was configured to provide most of the security:
 - it was configured with only a few global addresses to allow a small number of simultaneous connections for the initial trial, its stateful monitoring abilities being used to set up outgoing FTP in a secure manner,
 - it had two static mappings for the internal mail and news hosts from the proxies on the bastion host,
 - a ‘white list’ of acceptable destination sites was configured for connections in the outgoing direction,
- finally, the firewall was configured with the address of the firewall at the other end of the virtual network tunnel so that all communications between it and the remote site were encrypted.

8. Future direction

Firewall technology has advanced rapidly during the past few years, and will continue to evolve in the future. One of the main trends has been in combining the best aspects of all available firewall defence mechanisms, so that, rather than relying on one mechanism, manufacturers are integrating several different technologies into their products. An example is that of Cisco, who have taken network address translation and added it to their routers’ operating system [15]. It is expected that this trend will continue throughout the industry.

Many of the developments to date have been aimed at ironing out one or more weak spots in firewall technology. A prime example of this was the development of stateful monitoring, used by Sun [17], Checkpoint [18] and many others, which has solved the problem of how to use a packet screen to filter UDP based services effectively and enabled a much more secure way of filtering protocols such as FTP. This stateful approach will have to be taken in the future if new services that are based on multicast protocols are to be secured effectively. It is expected that products incorporating this type of technology will begin to appear within a year.

In the longer term, the Internet protocol specification is being developed towards a new world standard, IP V.6 [19]. In the security field, the work of the IPSec group is also evolving towards this goal, in which the ISAKMP/OAKLEY key management protocol will be mandatory.

This will require the support of a public-key infrastructure, similar to that described by Skevington and Hart [20].

Most the developments described act in the transport or application layers. In the near future, firewalls will act at an even higher level of the stack, at the level of the information itself. An example is the need to be able to verify the capabilities of mobile software, such as Java applets, which may have originated from untrustworthy sources. A firewall, being the boundary between the internal and external networks is the ideal place in the network to do this verification. An example of such an information level firewall is MimeSweeper, from Integralis [21]. This has the ability to scan incoming and outgoing messages for viruses encoded in e-mail attachments, and to quarantine any suspicious messages. Newer versions of the product can also be set to look for a number of key words in messages, and to prevent delivery of messages that contain more than a set number of these trigger words.

Firewalls are not the complete answer to connecting an organisation to the Internet in a secure manner. They can only ever be one weapon in the network administrator’s armoury. As they get more sophisticated, attackers will come up with new and interesting ways of gaining corporate information that do not involve breaching the firewall *per se*, but which act at the information level. Very recently, researchers at Princeton have published a paper describing a way of ‘spoofing’ the entire World Wide Web to an unsuspecting victim, using a combination of URL redirection, Java and Javascript [22]. One outcome of such an attack is the possibility of capturing all the victim’s keystrokes. Information level firewalls need to be able to detect such activities as URL redirection and the use of applets, and should at least be able to warn users that their browser may not be behaving in the way that they think that it is behaving.

9. Conclusions

The major firewall technologies have been reviewed. Each technology on its own has a particular set of merits, but the most secure firewalls are those which combine the best aspects of the available techniques. In common with most Internet-related technologies, firewalls are evolving quickly. The major challenge for firewall designers in the next few years is to come up with ways to combat new threats, especially those posed by mobile software technologies such as Java.

References

- 1 Chapman D B and Zwicky E D: ‘Building Internet Firewalls’, O’Reilly and Associates (1995).

- 2 'Timbuktu Pro Technical Guide', Farallon Computing Inc (1995).
- 3 Rekhter Y, Moskowitz R, Karrenberg D, de Groot G and Lear E: 'Address allocation for private internets', <http://ds.internic.net/rfc/rfc1918.txt> (1996).
- 4 Rudkin S et al: 'Real time applications on the Internet', *BT Technol J*, **15**, No 2, pp 208—224 (April 1997).
- 5 Hubbard S D and Antcliff S J: 'Firewalls for communications research', presented at UKERNA Workshop on Firewalls for Computer Security, <http://www.ukerna.ac.uk/newsfiles/janinfo/cert/Antcliff/BT-paper.pdf> (1996).
- 6 Atkinson R: 'Security architecture for the Internet protocol', <http://ds.internic.net/rfc/rfc1825.txt> (1995).
- 7 Atkinson R: 'IP authentication header', <http://ds.internic.net/rfc/rfc1826.txt> (1995).
- 8 Atkinson R: 'IP encapsulating security payload (ESP)', <http://ds.internic.net/rfc/rfc1827.txt> (1995).
- 9 Metzger P and Simpson W: 'IP authentication using keyed MD5', <http://ds.internic.net/rfc/rfc1828.txt> (1995).
- 10 Metzger P, Karn P and Simpson W: 'The ESP DES-CBC Transform', <http://ds.internic.net/rfc/rfc1829.txt> (1995).
- 11 <http://www.ietf.org/html.charters/ipsec-charter.html>
- 12 'Simple key management for Internet protocols (SKIP)', <ftp://ftp.ietf.org/internet-drafts/draft-ipsec-skip-07.txt> (1996).
- 13 'Internet security association and key management protocol (ISAKMP)', <ftp://ftp.ietf.org/internet-drafts/draft-ipsec-isakmp-06.txt> (1996).
- 14 'The OAKLEY key determination protocol', <ftp://ftp.ietf.org/internet-drafts/draft-ipsec-01.txt> (1996).
- 15 'Cisco IOS software solutions', <http://www.cisco.com/warp/public/732/index.html>
- 16 'Cisco PIX Firewall', <http://www.cisco.com/cpro/pub/univercd/ciscopro/catalog/cppix.htm>
- 17 'Sunscreens', <http://www.sun.com/950701/SunScreenFINAL.html>
- 18 'Stateful inspection firewall technology', <http://www.checkpoint.com/products/firewall/stateful/index.html>
- 19 Huitema C: 'IP V.6 — the new Internet protocol', Prentice-Hall Inc (1996).
- 20 Skevington P and Hart T P: 'Trusted third parties in electronic commerce', *BT Technol J*, **15**, No 2, pp 39—44 (April 1997).
- 21 'MimeSweeper home page', <http://www.mimesweeper.integralis.com>
- 22 Felten E W, Balfanz D, Dean D, Wallach D S: 'Web spoofing: an Internet con game', Technical Report 540—96, Dept of Computer Science, Princeton University; presented at DIMACS Workshop on Network Threats, <http://www.cs.princeton.edu/sip/pub/spoofing.html> (December 1996).



Steve Hubbard joined BT Laboratories in 1986, after completing BSc and PhD degrees in Physics at the University of Manchester in 1983 and 1986 respectively. On arriving at BTL, he worked on silica-based integrated optic devices for several years, before re-training in 1992 into the field of information security. Since 1992, he has been a member of the Security Futures research group. His current research interests include all aspects of Internet security.



John Sager joined BT in 1970 on graduating in Electronics from UMIST. After an initial spell in IC design he has spent most of his career in software engineering and system engineering roles. He was a member of the System X development team and later of the team that developed the BT Switched-Star cable TV system. More recently he has represented BT's interests in conditional access systems for pay-TV in several international collaborative groups developing specifications in this field. He is currently an engineering adviser in the security research group at BT Laboratories, with interests in multimedia security, network security and electronic commerce.